

Einführung

Angesichts der zunehmenden Bedrohung durch Cyberangriffe ist ein tiefgreifendes Verständnis der Angreifer, ihrer Motivationen und Methoden für die Entwicklung effektiver Sicherheitskonzepte unerlässlich. Mit den folgenden Arbeitsblätter lernt ihr die theoretischen Grundlagen von Angreifermodellen und den zentralen Schutzzielen der Informationssicherheit (Vertraulichkeit, Integrität und Verfügbarkeit).

Anschließend werdet ihr drei Fallbeispielen (WannaCry, Stuxnet und das Equifax-Datenleck) analysieren und die praktische Relevanz dieser Konzepte demonstrieren. Ihr werdet sehen, wie das jeweilige Angreiferprofil – von kriminell-finanzieller Motivation (WannaCry) über staatlich geförderte Spionage (Equifax) bis hin zu strategischer Sabotage (Stuxnet) – direkt bestimmt und welche Schutzziele primär verletzt werden.

Einleitung

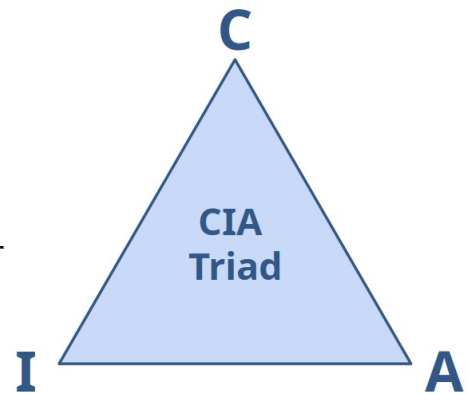
178,6 Mrd Euro betrug der Schaden durch Cybercrime im Jahr 2024 allein in deutschen Unternehmen. Cyberattacken sind für mehr als zwei Drittel der Schaden verantwortlich und 80% der Unternehmen haben 2023 eine Zunahme von Cyberangriffen verzeichnet [BK24]. Die Angriffe schaden nicht nur die Unternehmen, sondern auch deren Kunden, wie Privatpersonen. Um erfolgreiche Angriffe zu vermeiden oder wenigstens zu minimieren, ist die Cybersicherheit nicht wegzudenken.

In einem Sicherheitskonzept in Informationssystemen sind Angreifermodelle grundlegend, um damit konkret potenzielle Angreifer einzuschätzen. Mit diesem Modell werden Sicherheitsmechanismen eingebaut, die gegen potentielle Angreifer schützen sollen [FP02, S12].

Angreifer, die eine finanzielle Motivation haben, gehen anders vor als die, die aus Neugierde oder zum Üben der Fähigkeiten ein System angreifen. Angreifer, die globale Erpressungswellen starten, benötigen andere Sicherheitsmaßnahmen als Angreifer, die versuchen physisch die IT-Systeme zu manipulieren. All diese Angriffe können dennoch sehr gefährlich werden, müssen aber auch auf unterschiedliche Weisen verhindert werden [ECK18, S.22]. Die konkreten Gegenmaßnahmen gegen einen bestimmten Angreifertypen werden in Angreifermodellen festgehalten, um so besser auf konkrete Gefahren vorbereitet zu sein, als auf vage Bedrohungen.

Schutzziele

Daten von Entitäten sind von unberechtigten Personen nicht zu verändern und nicht einzusehen. Hat man die Daten von Dritten, dürfen diese rechtlichen nicht jedem frei zugänglich sein und müssen geschützt sein [RP09, S.1]. Um diesen Schutz zu gewährleisten, werden verschiedene Schutzziele verfolgt, die in der gängigen Literatur alle als Teilaspekte der grundlegenden drei Schutzziele dargestellt werden können [P08, S.20]. Damit diese Schutzziele effizient und zielgerichtet verfolgt werden können, werden Angreifermodelle erstellt und anhand dieser Sicherheitsmechanismen verwirklicht. Dabei muss man aber wissen, dass diese keine absolute Sicherheit gewährleisten kann [NOW10, S.10].



Daten in Informationssystemen müssen geschützt werden. Dabei müssen die **drei grundlegenden Schutzziele** Vertraulichkeit, Integrität und Verfügbarkeit der Daten gewährleistet werden. Diese Schutzziele werden in der englischsprachigen Literatur "CIA-Triad" genannt [CS14, S.21-23].

Vertraulichkeit (Confidentiality)

Wenn die Geheimhaltung kommunizierender Entitäten und Bekanntgabe von Informationen und Daten nur an berechnigte Entitäten gewährleistet ist, ist somit auch die Vertraulichkeit gewährleistet. Nachrichten in einem Messengerdienst dürfen bei diesem Schutzziel nicht an unberechtigte Dritte gelangen und es darf nicht nachvollzogen werden, welche Personen gegenseitig Nachrichten verschicken [PLÖ09, S.20-21; RP09, S.353]

Integrität (Integrity)

Werden Daten als Beweis in einem Gerichtsprozess eingereicht, muss sichergestellt werden, dass diese Daten nicht gefälscht sind und tatsächlich von der Person stammen, von der behauptet wird, von der sie stammen. Diese Gewährleistung stellt die Integrität von Daten dar. Außerhalb des Beispiels gilt, dass die Integrität gewährleistet ist, wenn Daten gesichert echt oder klar erkennbar nicht echt sind und die Daten tatsächlich von der angegebenen Person stammen [PLÖ09, S.24; RP09, S.353].

Verfügbarkeit (Availability)

Die Verfügbarkeit ist gewährleistet, wenn Daten und Informationen berechtigten Entitäten dann und dort zugänglich, wann und wo sie gebraucht werden. Wird also ein digitales Kartensystem genutzt, bei der ein Teil der Karte nicht verfügbar ist, ist die Verfügbarkeit nicht gewährleistet [PLÖ09, S.28 - 30; RP09, S.353].